

Universidad Autónoma de Nuevo León

Facultad de Ingeniería Mecánica y Eléctrica

Protocolos de Autenticación: Kerberos y RADIUS

Investigación Documental

Materia: Redes de Datos – Teoría

Actividad 12

Alumno: Angel Lara

Fecha: 29 de abril de 2026

Semestre Agosto – Diciembre 2026

Índice

1. Introducción	3
2. Marco teórico	4
2.1. Concepto de autenticación en redes	4
2.2. Modelo AAA (Autenticación, Autorización y Contabilidad)	4
2.3. Criptografía simétrica y su papel en la autenticación	4
3. Protocolo Kerberos	5
3.1. Orígenes y desarrollo histórico	5
3.2. Componentes principales	5
3.2.1. Centro de Distribución de Claves (KDC)	5
3.2.2. Servidor de Autenticación (AS)	5
3.2.3. Servidor de Concesión de Tickets (TGS)	6
3.3. Funcionamiento y proceso de autenticación	6
3.4. Características principales	7
3.5. Seguridad en Kerberos	8
3.5.1. Fortalezas de seguridad	8
3.5.2. Vulnerabilidades conocidas	8
4. Protocolo RADIUS	9
4.1. Orígenes y desarrollo histórico	9
4.2. Componentes principales	9
4.2.1. Cliente RADIUS (NAS)	9
4.2.2. Servidor RADIUS	10
4.2.3. Base de datos de usuarios	10
4.3. Funcionamiento y proceso de autenticación	10
4.4. Características principales	11
4.5. Seguridad en RADIUS	12
4.5.1. Fortalezas de seguridad	12
4.5.2. Vulnerabilidades conocidas	13
5. Tabla comparativa entre Kerberos y RADIUS	13
6. Empresas y organizaciones que utilizan Kerberos y RADIUS	15
6.1. Empresas que implementan Kerberos	15
6.2. Empresas que implementan RADIUS	16
7. Análisis	17

8. Conclusiones	18
9. Fuentes de información	19

1. Introducción

En el contexto actual de las redes de comunicación, donde millones de dispositivos intercambian información de manera constante, la seguridad se ha convertido en uno de los pilares fundamentales para garantizar la integridad, la confidencialidad y la disponibilidad de los datos. Cada vez que un usuario intenta acceder a un recurso dentro de una red corporativa, educativa o incluso doméstica, existe un proceso invisible pero crítico que se lleva a cabo en segundo plano: la autenticación. Este proceso tiene como objetivo verificar que quien solicita el acceso sea realmente quien dice ser, y no un agente malicioso que pretenda suplantar su identidad.

A lo largo de las últimas décadas, se han desarrollado diversos protocolos y mecanismos de autenticación que buscan resolver este problema de forma eficiente y segura. Entre los más relevantes y ampliamente utilizados en entornos empresariales y de telecomunicaciones se encuentran Kerberos y RADIUS. Ambos protocolos, aunque comparten el objetivo general de validar identidades, presentan diferencias sustanciales en su diseño, arquitectura y aplicación práctica, lo que los hace adecuados para escenarios muy distintos.

Kerberos, desarrollado originalmente en el Instituto Tecnológico de Massachusetts (MIT) durante la década de 1980, fue concebido como un protocolo de autenticación basado en tickets criptográficos que permite a los usuarios acceder a múltiples servicios dentro de una red sin necesidad de transmitir sus contraseñas por el canal de comunicación. Este enfoque resultó revolucionario en su momento y sigue siendo la base del sistema de autenticación en entornos de Active Directory de Microsoft, así como en numerosas plataformas Unix y Linux.

Por otro lado, RADIUS (Remote Authentication Dial-In User Service) surgió a principios de la década de 1990 como una solución para gestionar el acceso remoto de usuarios que se conectaban a redes a través de líneas telefónicas. Con el paso del tiempo, su utilidad se extendió a la administración de accesos en redes inalámbricas, VPN y redes de proveedores de servicios de internet (ISP), convirtiéndose en un estándar para la gestión centralizada de autenticación, autorización y contabilidad, lo que comúnmente se conoce como el modelo AAA.

La presente investigación tiene como propósito realizar un análisis detallado de ambos protocolos, abordando sus orígenes, su funcionamiento interno, las características que los definen, los mecanismos de seguridad que implementan y el proceso específico de autenticación que cada uno lleva a cabo. Además, se presenta una tabla comparativa que permite visualizar de forma clara las diferencias y similitudes entre Kerberos y RADIUS, así como un listado de organizaciones y empresas que han adoptado cada protocolo en sus infraestructuras tecnológicas. Con todo ello, se busca ofrecer una visión integral que

permita comprender la importancia de estos mecanismos dentro del panorama actual de la seguridad en redes.

2. Marco teórico

2.1. Concepto de autenticación en redes

La autenticación es el proceso mediante el cual un sistema verifica la identidad de un usuario, dispositivo o entidad que solicita acceso a un recurso determinado. En el ámbito de las redes de datos, este proceso resulta indispensable para evitar accesos no autorizados que puedan comprometer la seguridad de la información. Existen distintos métodos de autenticación, que van desde el uso de contraseñas simples hasta sistemas más sofisticados basados en certificados digitales, tokens criptográficos o datos biométricos.

2.2. Modelo AAA (Autenticación, Autorización y Contabilidad)

El modelo AAA es un marco conceptual que agrupa tres funciones esenciales para la gestión del acceso a recursos en una red. La primera función, la autenticación, se encarga de verificar la identidad del usuario. La segunda, la autorización, define qué recursos y servicios puede utilizar ese usuario una vez autenticado. La tercera, la contabilidad (o *accounting*), registra las acciones realizadas por el usuario durante su sesión, lo que resulta útil para auditorías, facturación y análisis de uso. RADIUS implementa las tres funciones de este modelo de manera nativa, mientras que Kerberos se centra principalmente en la autenticación, dejando la autorización y la contabilidad a otros componentes del sistema.

2.3. Criptografía simétrica y su papel en la autenticación

La criptografía simétrica es un método de cifrado en el que tanto el emisor como el receptor comparten una misma clave secreta para cifrar y descifrar los mensajes. Kerberos utiliza este tipo de criptografía de forma extensiva: las comunicaciones entre el cliente, el servidor de autenticación y el servidor de concesión de tickets se protegen mediante claves compartidas, lo que evita que las contraseñas viajen en texto claro a través de la red. Algoritmos como AES (Advanced Encryption Standard) y DES (Data Encryption Standard) han sido utilizados en distintas versiones de Kerberos para asegurar estas comunicaciones.

3. Protocolo Kerberos

3.1. Orígenes y desarrollo histórico

Kerberos fue desarrollado como parte del proyecto Athena en el MIT durante los años ochenta. El nombre del protocolo hace referencia a Cérbero, el perro de tres cabezas que, según la mitología griega, custodiaba las puertas del inframundo. Esta analogía resulta apropiada, ya que el protocolo se apoya en tres componentes principales para resguardar el acceso a los recursos de una red. La primera versión funcional que se distribuyó de forma pública fue Kerberos v4, aunque la versión que se utiliza en la actualidad es Kerberos v5, definida en el RFC 4120. Esta versión corrige diversas limitaciones de su predecesora, como la dependencia exclusiva del algoritmo DES y la falta de soporte para delegación de credenciales.

3.2. Componentes principales

El funcionamiento de Kerberos se apoya en tres entidades fundamentales que interactúan durante el proceso de autenticación:

3.2.1. Centro de Distribución de Claves (KDC)

El KDC es el componente central del sistema Kerberos. Se trata de un servidor de confianza que almacena las claves secretas de todos los usuarios y servicios registrados en el dominio. El KDC se compone internamente de dos servicios diferenciados: el Servidor de Autenticación (AS) y el Servidor de Concesión de Tickets (TGS). Ambos trabajan de manera coordinada para emitir los tickets que permiten a los usuarios acceder a los servicios de la red sin necesidad de enviar sus credenciales repetidamente.

3.2.2. Servidor de Autenticación (AS)

El AS es la primera entidad con la que interactúa el cliente al momento de iniciar sesión. Su función consiste en verificar la identidad del usuario a partir de sus credenciales y, en caso de que la verificación sea exitosa, emitir un Ticket de Concesión de Tickets (TGT). Este TGT funciona como una especie de pase temporal que el usuario podrá presentar ante el TGS para solicitar acceso a servicios específicos.

3.2.3. Servidor de Concesión de Tickets (TGS)

El TGS recibe las solicitudes de acceso a servicios por parte de los usuarios que ya poseen un TGT válido. Al recibir dicha solicitud, el TGS valida el TGT y, si todo es correcto, emite un ticket de servicio (ST) que el usuario puede presentar directamente ante el servidor que aloja el recurso solicitado. De esta forma, el servidor del recurso puede verificar la identidad del usuario sin necesidad de contactar nuevamente al KDC.

3.3. Funcionamiento y proceso de autenticación

El proceso de autenticación en Kerberos se lleva a cabo en varias etapas claramente definidas, las cuales se describen a continuación de forma detallada:

Paso 1: Solicitud de autenticación inicial. Cuando un usuario desea acceder a la red, introduce su nombre de usuario y contraseña en su equipo. El cliente genera una solicitud de autenticación (AS-REQ) que envía al Servidor de Autenticación del KDC. Es importante señalar que la contraseña del usuario nunca se transmite a través de la red; en su lugar, se utiliza para derivar una clave criptográfica que se emplea en el proceso.

Paso 2: Emisión del TGT. El AS busca al usuario en su base de datos y, si lo encuentra, genera un Ticket de Concesión de Tickets (TGT). Este ticket está cifrado con la clave secreta del servicio TGS, de modo que solo el TGS puede descifrarlo. Además, el AS envía al cliente una clave de sesión cifrada con la clave derivada de la contraseña del usuario. De esta manera, solo el usuario legítimo puede descifrar la clave de sesión y utilizar el TGT.

Paso 3: Solicitud de ticket de servicio. Cuando el usuario necesita acceder a un servicio específico, su equipo envía una solicitud al TGS (TGS-REQ) que incluye el TGT previamente obtenido, junto con un autenticador cifrado con la clave de sesión. El autenticador contiene información como la identidad del usuario y una marca de tiempo, lo que ayuda a prevenir ataques de repetición.

Paso 4: Emisión del ticket de servicio. El TGS descifra el TGT, extrae la clave de sesión y la utiliza para descifrar el autenticador. Si la información coincide y el ticket es válido, el TGS genera un ticket de servicio (ST) cifrado con la clave secreta del servidor de destino, junto con una nueva clave de sesión para la comunicación entre el cliente y el servicio.

Paso 5: Acceso al servicio. El cliente presenta el ticket de servicio al servidor que aloja el recurso solicitado. El servidor descifra el ticket con su propia clave secreta, verifica la identidad del usuario y, si todo es correcto, concede el acceso. En este punto, el servidor

también puede autenticarse ante el cliente, lo que constituye la autenticación mutua, una de las características más destacadas de Kerberos.

Paso 6: Comunicación segura. Una vez que ambas partes se han autenticado mutuamente, la comunicación entre el cliente y el servidor se puede proteger utilizando la clave de sesión compartida, lo que garantiza la confidencialidad e integridad de los datos intercambiados.

3.4. Características principales

Kerberos presenta una serie de características que lo distinguen de otros protocolos de autenticación y que han contribuido a su adopción masiva en entornos empresariales:

- **Autenticación mutua:** Tanto el cliente como el servidor verifican la identidad del otro, lo que reduce significativamente el riesgo de ataques de suplantación.
- **Inicio de sesión único (SSO):** Una vez que el usuario obtiene un TGT, puede acceder a múltiples servicios dentro del dominio sin necesidad de volver a introducir sus credenciales, lo que mejora la experiencia del usuario y reduce la carga administrativa.
- **No transmisión de contraseñas:** Las contraseñas nunca viajan por la red en ningún formato. En su lugar, se utilizan claves derivadas y tickets cifrados, lo que minimiza el riesgo de interceptación.
- **Tickets con tiempo de vida limitado:** Cada ticket tiene una marca de tiempo y un período de validez definido, lo que dificulta los ataques de repetición y limita la ventana de exposición en caso de compromiso.
- **Cifrado robusto:** Las versiones actuales de Kerberos soportan algoritmos de cifrado modernos como AES-256, lo que proporciona un nivel de seguridad acorde con los estándares contemporáneos.
- **Interoperabilidad:** Kerberos v5 es compatible con múltiples sistemas operativos, incluyendo Windows, macOS, Linux y diversas variantes de Unix, lo que facilita su integración en entornos heterogéneos.
- **Delegación de credenciales:** Kerberos v5 permite que un servicio actúe en nombre de un usuario ante otro servicio, lo cual resulta útil en arquitecturas de múltiples capas.

3.5. Seguridad en Kerberos

A pesar de ser considerado uno de los protocolos de autenticación más seguros, Kerberos no está exento de vulnerabilidades y riesgos que deben ser considerados por los administradores de red.

3.5.1. Fortalezas de seguridad

La principal fortaleza de Kerberos radica en que las contraseñas nunca se transmiten a través de la red. El uso de criptografía simétrica para proteger los tickets y las claves de sesión añade una capa adicional de protección. Además, la autenticación mutua garantiza que tanto el cliente como el servidor son entidades legítimas, lo que previene ataques de tipo *man-in-the-middle*. Las marcas de tiempo incorporadas en los tickets también dificultan los ataques de repetición, ya que un ticket capturado por un atacante tendrá una ventana de validez muy limitada.

3.5.2. Vulnerabilidades conocidas

Entre las vulnerabilidades más significativas de Kerberos se encuentran los llamados ataques de *Golden Ticket* y *Silver Ticket*. En un ataque de *Golden Ticket*, el atacante logra obtener el hash de la contraseña de la cuenta KRBTGT, que es la cuenta de servicio del KDC responsable de firmar todos los TGT. Con este hash, el atacante puede generar TGT falsos con privilegios arbitrarios y con períodos de validez extremadamente largos, lo que le otorga acceso irrestricto a todos los recursos del dominio. La única forma de remediar este tipo de ataque consiste en restablecer la contraseña de la cuenta KRBTGT dos veces, ya que Active Directory almacena tanto la contraseña actual como la anterior.

El ataque de *Silver Ticket* es similar, pero opera a nivel de un servicio individual. El atacante obtiene el hash de la contraseña de la cuenta de servicio y genera tickets de servicio falsos que le permiten acceder a ese servicio específico sin necesidad de interactuar con el KDC.

Otra vulnerabilidad relevante es la dependencia de la sincronización del reloj entre los equipos participantes. Kerberos requiere que los relojes de los clientes y los servidores estén sincronizados con una diferencia máxima de cinco minutos. Si un atacante logra manipular el reloj de un equipo, podría provocar fallos en la autenticación o facilitar la reutilización de tickets expirados.

Adicionalmente, el KDC representa un punto único de fallo. Si el servidor que aloja el KDC queda fuera de servicio, ningún usuario podrá autenticarse ni acceder a los recursos

de la red. Por esta razón, en entornos de producción se recomienda implementar KDC redundantes que garanticen la disponibilidad del servicio.

4. Protocolo RADIUS

4.1. Orígenes y desarrollo histórico

El protocolo RADIUS fue desarrollado originalmente por la empresa Livingston Enterprises en 1991, en respuesta a la necesidad de los proveedores de servicios de internet de gestionar de forma centralizada la autenticación de los usuarios que se conectaban a sus redes mediante conexiones de marcado telefónico (*dial-up*). En aquella época, cada servidor de acceso remoto (NAS, por sus siglas en inglés) mantenía su propia base de datos de usuarios, lo que resultaba ineficiente y difícil de administrar a medida que el número de suscriptores crecía. RADIUS ofreció una solución elegante al centralizar toda la información de autenticación en un único servidor, al cual los distintos NAS podían consultar.

Con el tiempo, RADIUS fue estandarizado por la IETF (Internet Engineering Task Force) y sus especificaciones se documentaron en diversos RFC, siendo los más relevantes el RFC 2865 para la autenticación y autorización, y el RFC 2866 para la contabilidad. Desde entonces, el protocolo ha evolucionado para adaptarse a las necesidades de las redes modernas, soportando autenticación en redes inalámbricas, VPN, conmutadores de red con 802.1X y más.

4.2. Componentes principales

La arquitectura de RADIUS se basa en un modelo cliente-servidor que involucra tres componentes fundamentales:

4.2.1. Cliente RADIUS (NAS)

El cliente RADIUS, también conocido como Network Access Server (NAS), es el dispositivo de red que recibe la solicitud de conexión del usuario y la reenvía al servidor RADIUS para su validación. Ejemplos típicos de clientes RADIUS incluyen puntos de acceso inalámbricos, concentradores VPN, conmutadores de red con soporte para 802.1X y servidores de acceso remoto.

4.2.2. Servidor RADIUS

El servidor RADIUS es la entidad central que recibe las solicitudes de autenticación provenientes de los clientes RADIUS, las procesa comparándolas contra una base de datos de usuarios y responde con una decisión de aceptación o rechazo. Además de la autenticación, el servidor RADIUS también se encarga de aplicar políticas de autorización, como la asignación de VLAN, la limitación del ancho de banda o la restricción de horarios de acceso. Existen diversas implementaciones de servidores RADIUS, tanto comerciales como de código abierto, siendo FreeRADIUS una de las más populares en el segundo grupo.

4.2.3. Base de datos de usuarios

El servidor RADIUS puede consultar diversas fuentes de información para verificar las credenciales de los usuarios, tales como archivos locales, bases de datos SQL, directorios LDAP o incluso otros servidores RADIUS configurados en modo proxy. Esta flexibilidad permite a las organizaciones integrar RADIUS con su infraestructura de identidad existente sin necesidad de duplicar la información de los usuarios.

4.3. Funcionamiento y proceso de autenticación

El proceso de autenticación en RADIUS sigue un flujo relativamente sencillo, aunque admite variaciones dependiendo del método de autenticación utilizado. A continuación se describe el flujo general:

Paso 1: Solicitud de conexión del usuario. El usuario intenta conectarse a la red a través de un dispositivo de acceso, como un punto de acceso Wi-Fi o un concentrador VPN. El dispositivo le solicita sus credenciales, que generalmente consisten en un nombre de usuario y una contraseña.

Paso 2: Envío del paquete Access-Request. El cliente RADIUS (NAS) construye un paquete de tipo `Access-Request` que contiene la información del usuario, incluyendo su nombre de usuario, la contraseña cifrada mediante un secreto compartido entre el NAS y el servidor RADIUS, la dirección IP del NAS y el puerto desde el cual se origina la solicitud. Este paquete se envía al servidor RADIUS utilizando el protocolo UDP, generalmente a través de los puertos 1812 (autenticación) y 1813 (contabilidad).

Paso 3: Procesamiento en el servidor RADIUS. El servidor RADIUS recibe el paquete, extrae la información del usuario y la compara contra su base de datos. Si las credenciales coinciden, el servidor verifica las políticas de autorización asociadas a ese usuario para determinar qué nivel de acceso debe otorgarle.

Paso 4: Respuesta del servidor. El servidor RADIUS envía una de las siguientes respuestas al NAS:

- **Access-Accept:** Las credenciales son válidas y el usuario tiene permiso para acceder a la red. La respuesta puede incluir atributos adicionales que definen las condiciones del acceso, como la VLAN asignada, el ancho de banda máximo permitido o el tiempo máximo de sesión.
- **Access-Reject:** Las credenciales son inválidas o el usuario no tiene permiso para acceder. El NAS deniega la conexión.
- **Access-Challenge:** El servidor requiere información adicional del usuario antes de tomar una decisión, lo que permite implementar mecanismos de autenticación de múltiples factores.

Paso 5: Concesión o denegación del acceso. Con base en la respuesta del servidor RADIUS, el NAS permite o bloquea el acceso del usuario a la red.

Paso 6: Contabilidad de la sesión. Si el usuario fue autenticado exitosamente, el NAS envía paquetes de contabilidad (**Accounting-Request**) al servidor RADIUS para registrar el inicio y el fin de la sesión, así como datos de uso como el volumen de tráfico transmitido y recibido, la duración de la sesión y la causa de la desconexión.

4.4. Características principales

RADIUS presenta un conjunto de características que lo han convertido en un estándar ampliamente adoptado para la gestión del acceso a redes:

- **Modelo AAA integrado:** RADIUS implementa de forma nativa las tres funciones del modelo AAA (autenticación, autorización y contabilidad), lo que permite gestionar de manera centralizada todo el ciclo de vida del acceso de un usuario.
- **Protocolo basado en UDP:** RADIUS utiliza el protocolo de transporte UDP, lo que lo hace ligero y eficiente en términos de consumo de recursos de red. Sin embargo, la falta de garantía de entrega inherente a UDP requiere que las implementaciones incluyan mecanismos propios de retransmisión.
- **Soporte para múltiples métodos de autenticación:** RADIUS es compatible con diversos protocolos de autenticación, incluyendo PAP (Password Authentication Protocol), CHAP (Challenge-Handshake Authentication Protocol) y EAP (Extensible Authentication Protocol), lo que le permite adaptarse a diferentes requisitos de seguridad.

- **Extensibilidad mediante atributos:** El protocolo utiliza un sistema de pares atributo-valor (AVP) que permite incluir información adicional en los paquetes de solicitud y respuesta. Los fabricantes de equipos de red pueden definir atributos propietarios (*Vendor-Specific Attributes*) para soportar funcionalidades específicas de sus productos.
- **Alta escalabilidad:** RADIUS puede administrar cientos de miles o incluso millones de usuarios de forma centralizada, lo que lo hace especialmente adecuado para proveedores de servicios de internet y grandes organizaciones.
- **Soporte para proxy:** Los servidores RADIUS pueden funcionar en modo proxy, reenviando las solicitudes de autenticación a otros servidores RADIUS en dominios diferentes, lo que facilita la implementación de arquitecturas federadas y acuerdos de roaming.
- **Registro detallado de sesiones:** La funcionalidad de contabilidad de RADIUS permite a las organizaciones llevar un registro detallado de las sesiones de los usuarios, lo que resulta útil tanto para la facturación como para la auditoría de seguridad.

4.5. Seguridad en RADIUS

La seguridad del protocolo RADIUS se sustenta en varios mecanismos, aunque también presenta ciertas limitaciones que deben ser consideradas.

4.5.1. Fortalezas de seguridad

RADIUS utiliza un secreto compartido entre el cliente y el servidor para cifrar la contraseña del usuario en los paquetes **Access-Request**, lo que evita que esta viaje en texto claro por la red. Además, el soporte para el protocolo EAP permite implementar métodos de autenticación avanzados, como EAP-TLS (basado en certificados digitales), EAP-TTLS y PEAP, que proporcionan un nivel de seguridad significativamente mayor que PAP o CHAP.

La centralización de la autenticación también constituye una ventaja de seguridad, ya que permite aplicar políticas consistentes a todos los puntos de acceso de la red y facilita la detección de anomalías en los patrones de acceso.

En años recientes, la aparición de RadSec (RADIUS sobre TLS) ha abordado una de las principales críticas al protocolo original: la falta de cifrado integral de los paquetes. RadSec encapsula los mensajes RADIUS dentro de una conexión TLS, lo que garantiza

la confidencialidad e integridad de toda la comunicación entre el cliente y el servidor RADIUS.

4.5.2. Vulnerabilidades conocidas

Una de las debilidades históricas de RADIUS es que, en su implementación estándar, únicamente cifra la contraseña del usuario dentro del paquete **Access-Request**, mientras que el resto de los atributos se transmiten en texto claro. Esto significa que un atacante que capture el tráfico de red podría obtener información sensible como el nombre de usuario, la dirección IP del NAS o los parámetros de autorización.

El uso de UDP como protocolo de transporte también introduce riesgos, ya que UDP es susceptible a ataques de suplantación de dirección IP (*IP spoofing*). Un atacante podría enviar respuestas falsas al NAS haciéndose pasar por el servidor RADIUS, lo que podría resultar en la autorización de accesos no legítimos.

Otra vulnerabilidad relevante se relaciona con la fortaleza del secreto compartido. Si el secreto compartido entre el NAS y el servidor RADIUS es débil o se ve comprometido, un atacante podría descifrar las contraseñas de los usuarios y falsificar mensajes RADIUS. Por esta razón, se recomienda utilizar secretos compartidos largos y complejos, y rotarlos periódicamente.

Finalmente, RADIUS no ofrece autenticación mutua de forma nativa. El NAS confía en que la respuesta proviene del servidor RADIUS legítimo únicamente sobre la base del secreto compartido, lo que lo hace potencialmente vulnerable a ataques de intermediario si el secreto se ve comprometido.

5. Tabla comparativa entre Kerberos y RADIUS

A continuación se presenta una tabla que sintetiza las principales diferencias y similitudes entre ambos protocolos, lo que permite visualizar de forma clara las fortalezas y limitaciones de cada uno en distintos aspectos.

Cuadro 1: Comparación entre los protocolos Kerberos y RADIUS

Criterio	Kerberos	RADIUS
Tipo de protocolo	Protocolo de autenticación basado en tickets criptográficos	Protocolo AAA (autenticación, autorización y contabilidad)
Origen	MIT, proyecto Athena (década de 1980)	Livingston Enterprises (1991), estandarizado por la IETF
Modelo de funcionamiento	Cliente–KDC–Servidor de servicio	Cliente (NAS)–Servidor RADIUS
Protocolo de transporte	TCP y UDP (puerto 88)	UDP (puertos 1812 y 1813)
Cifrado	Cifrado completo de tickets y claves de sesión mediante criptografía simétrica (AES, DES)	Cifrado parcial: solo la contraseña en el paquete Access-Request (salvo con RadSec)
Autenticación mutua	Sí, tanto el cliente como el servidor se autentican mutuamente	No de forma nativa; depende del secreto compartido
Inicio de sesión único (SSO)	Sí, mediante el uso del TGT	No soporta SSO de forma nativa
Contabilidad	No incluye funcionalidad de contabilidad nativa	Sí, contabilidad detallada de sesiones (inicio, fin, volumen de datos)
Escalabilidad	Limitada al dominio o <i>realm</i> ; la inter-operación entre dominios requiere relaciones de confianza	Alta escalabilidad; soporta millones de usuarios y configuraciones de proxy
Principales usos	Autenticación en redes corporativas, Active Directory, servicios internos	Acceso remoto, redes Wi-Fi, VPN, ISP, redes 802.1X
Dependencia de sincronización temporal	Sí, requiere sincronización de relojes con tolerancia máxima de 5 minutos	No requiere sincronización temporal
Punto único de fallo	El KDC; se mitiga con servidores redundantes	El servidor RADIUS; se mitiga con redundancia y failover
Transmisión de contraseñas	Nunca se transmiten contraseñas por la red	Se transmite la contraseña cifrada con el secreto compartido
Estandarización	RFC 4120 (Kerberos v5)	RFC 2865 (autenticación), RFC 2866 (contabilidad)

6. Empresas y organizaciones que utilizan Kerberos y RADIUS

6.1. Empresas que implementan Kerberos

Kerberos ha sido adoptado por una amplia gama de empresas y organizaciones tecnológicas que lo integran en sus productos y sistemas internos. A continuación se presenta un listado de las más relevantes:

1. **Microsoft:** Kerberos es el protocolo de autenticación predeterminado en Windows Active Directory desde la versión de Windows 2000. Todos los entornos empresariales basados en Windows Server utilizan Kerberos de forma extensiva para la autenticación de usuarios, equipos y servicios dentro del dominio.
2. **Apple:** El sistema operativo macOS incluye soporte nativo para Kerberos, lo que permite a los equipos Mac integrarse en entornos de Active Directory y autenticarse mediante este protocolo.
3. **Oracle:** La base de datos Oracle y otros productos de la compañía soportan autenticación mediante Kerberos, lo que permite a las organizaciones integrar el acceso a sus bases de datos con la infraestructura de autenticación centralizada.
4. **Google:** La infraestructura interna de Google utiliza Kerberos para la autenticación de sus empleados en diversos servicios internos. Además, Google Cloud Platform ofrece soporte para Kerberos en determinados servicios.
5. **Cisco:** Los equipos de red de Cisco soportan autenticación mediante Kerberos, lo que permite integrarlos en entornos de directorio activo y otras infraestructuras basadas en este protocolo.
6. **Amazon Web Services (AWS):** AWS ofrece soporte para Kerberos a través de su servicio AWS Managed Microsoft AD, que permite crear dominios de Active Directory en la nube con autenticación Kerberos.
7. **Red Hat / IBM:** Las distribuciones de Linux empresariales como Red Hat Enterprise Linux incluyen implementaciones de Kerberos (MIT Kerberos y Heimdal) y herramientas como FreeIPA para gestionar la autenticación centralizada en entornos Linux.
8. **Intel:** Intel ha participado en el desarrollo y la adopción de estándares de Kerberos, integrando soporte para este protocolo en diversas soluciones de

infraestructura.

9. **Microsoft Azure:** Azure Active Directory Domain Services ofrece soporte completo para Kerberos, lo que permite a las organizaciones migrar sus cargas de trabajo a la nube manteniendo la autenticación basada en tickets.

6.2. Empresas que implementan RADIUS

RADIUS es utilizado por una variedad aún más amplia de organizaciones, dado que su enfoque en la gestión del acceso a redes lo hace indispensable en múltiples sectores:

1. **Cisco:** Cisco es uno de los principales promotores de RADIUS en el ámbito de las redes empresariales. Sus conmutadores, routers y controladores de red inalámbrica integran clientes RADIUS para gestionar el acceso a la red mediante 802.1X.
2. **AT&T:** Como uno de los mayores proveedores de servicios de telecomunicaciones del mundo, AT&T utiliza servidores RADIUS para autenticar a millones de suscriptores que se conectan a sus redes de banda ancha y servicios móviles.
3. **Comcast:** Al igual que otros grandes ISP, Comcast emplea RADIUS para gestionar la autenticación y la contabilidad de los usuarios que acceden a su red de internet residencial y comercial.
4. **Verizon:** Verizon utiliza infraestructura RADIUS para la gestión del acceso de sus clientes de servicios de internet y comunicaciones empresariales.
5. **Aruba Networks (Hewlett Packard Enterprise):** Los controladores de red inalámbrica de Aruba integran clientes RADIUS para la autenticación de usuarios en redes Wi-Fi empresariales con 802.1X.
6. **Juniper Networks:** Los equipos de red de Juniper soportan RADIUS como mecanismo de autenticación, tanto para el acceso de usuarios a la red como para la administración de los propios equipos.
7. **Universidades e instituciones educativas:** Redes académicas como Eduroam utilizan RADIUS como columna vertebral de su sistema de autenticación, permitiendo a estudiantes y personal académico acceder a redes Wi-Fi de instituciones participantes en todo el mundo mediante un sistema federado de autenticación.
8. **Fortinet:** Los firewalls y controladores de red de Fortinet soportan integración con servidores RADIUS para la autenticación de usuarios en redes corporativas y VPN.

9. **Deutsche Telekom:** El operador de telecomunicaciones alemán utiliza infraestructura RADIUS para la gestión del acceso de sus millones de suscriptores de banda ancha en Europa.
10. **Telefónica:** El grupo de telecomunicaciones español emplea servidores RADIUS en sus operaciones en Latinoamérica y Europa para la autenticación de clientes de servicios de internet y comunicaciones.

7. Análisis

Al examinar ambos protocolos en conjunto, resulta evidente que Kerberos y RADIUS no son tecnologías que compitan directamente entre sí, sino que más bien se complementan al abordar necesidades distintas dentro del espectro de la autenticación y la gestión del acceso a redes.

Kerberos destaca en entornos donde la autenticación mutua y el inicio de sesión único son requisitos fundamentales. Su diseño basado en tickets criptográficos elimina la necesidad de transmitir contraseñas a través de la red, lo que representa una ventaja significativa frente a protocolos que dependen del envío de credenciales cifradas. Sin embargo, esta robustez tiene un costo: la complejidad de la infraestructura necesaria para su implementación, que incluye la configuración y el mantenimiento de servidores KDC, la sincronización de relojes y la gestión de relaciones de confianza entre dominios. Además, las vulnerabilidades como los ataques de *Golden Ticket* demuestran que, si bien el protocolo en sí es sólido, su seguridad depende en gran medida de la correcta administración de las cuentas de servicio y de las políticas de seguridad del dominio.

RADIUS, por su parte, sobresale en escenarios donde la escalabilidad, la flexibilidad y la capacidad de contabilidad son prioritarias. Su adopción masiva por parte de proveedores de servicios de internet y en redes inalámbricas empresariales se debe en gran medida a su capacidad para gestionar millones de usuarios de forma centralizada y a su soporte para una amplia variedad de métodos de autenticación. No obstante, el cifrado parcial de los paquetes RADIUS representa una limitación que ha sido parcialmente subsanada con la aparición de RadSec, aunque su adopción aún no es universal.

En la práctica, muchas organizaciones utilizan ambos protocolos de manera complementaria. Por ejemplo, una empresa puede utilizar Kerberos para la autenticación de usuarios en su red corporativa interna a través de Active Directory, mientras que emplea RADIUS para gestionar el acceso a su red Wi-Fi corporativa y a las conexiones VPN de sus empleados remotos. En este escenario, el servidor RADIUS puede estar configurado para consultar el directorio de Active Directory como fuente de autenticación, lo que crea una

integración transparente entre ambos protocolos.

Desde una perspectiva de seguridad, es importante reconocer que ningún protocolo de autenticación es infalible por sí solo. La seguridad de un sistema depende no solo del protocolo utilizado, sino también de las políticas de gestión de contraseñas, la configuración de los servidores, la segmentación de la red, la monitorización de eventos de seguridad y la formación de los usuarios. Tanto Kerberos como RADIUS ofrecen herramientas poderosas para proteger el acceso a los recursos de una red, pero su eficacia depende de una implementación cuidadosa y de un mantenimiento continuo.

8. Conclusiones

A lo largo de esta investigación se han analizado dos de los protocolos de autenticación más importantes y ampliamente utilizados en el ámbito de las redes de datos: Kerberos y RADIUS. Cada uno de ellos fue diseñado para resolver problemáticas específicas, y su evolución a lo largo de las décadas refleja la creciente complejidad de los entornos de red y las amenazas de seguridad que enfrentan.

Kerberos ha demostrado ser una solución robusta para la autenticación en redes corporativas, particularmente en entornos basados en Active Directory. Su enfoque basado en tickets criptográficos, la autenticación mutua y el soporte para inicio de sesión único lo convierten en una elección natural para organizaciones que requieren un alto nivel de seguridad en sus redes internas. Sin embargo, su implementación exige una planificación cuidadosa y una administración rigurosa para mitigar las vulnerabilidades inherentes a su arquitectura, como los ataques de *Golden Ticket* y la dependencia de la sincronización temporal.

RADIUS, por otro lado, ha demostrado su valor como solución estándar para la gestión del acceso a redes en una amplia variedad de contextos, desde proveedores de servicios de internet hasta redes inalámbricas empresariales y académicas. Su implementación del modelo AAA, su alta escalabilidad y su flexibilidad para integrarse con diversas fuentes de autenticación lo convierten en una pieza clave de la infraestructura de red de innumerables organizaciones en todo el mundo.

En definitiva, la elección entre Kerberos y RADIUS no debe plantearse como una disyuntiva excluyente, sino como una decisión que depende del contexto específico de cada organización. En muchos casos, la estrategia más efectiva consiste en utilizar ambos protocolos de manera complementaria, aprovechando las fortalezas de cada uno para construir una infraestructura de autenticación sólida, escalable y adaptada a las necesidades particulares del entorno.

El estudio de estos protocolos resulta fundamental para cualquier profesional de las redes y la seguridad informática, ya que comprender su funcionamiento interno, sus fortalezas y sus limitaciones constituye la base para diseñar e implementar soluciones de autenticación que protejan de manera efectiva los recursos y la información de las organizaciones frente a las amenazas actuales y futuras.

9. Fuentes de información

1. Fortinet. (s.f.). *What Is Kerberos? Kerberos Authentication Explained*. Recuperado de: <https://www.fortinet.com/resources/cyberglossary/kerberos-authentication>
2. Cisco Systems. (s.f.). *Examine how the RADIUS Works*. Recuperado de: <https://www.cisco.com/c/en/us/support/docs/security-vpn/remote-authentication-dial-12433-32.html>
3. TechTarget. (s.f.). *What is Kerberos and How Does It Work?*. Recuperado de: <https://www.techtarget.com/searchsecurity/definition/Kerberos>
4. TechTarget. (s.f.). *What is RADIUS (Remote Authentication Dial-In User Service)?*. Recuperado de: <https://www.techtarget.com/searchsecurity/definition/RADIUS>
5. MIT Kerberos Consortium. (s.f.). *Kerberos: The Network Authentication Protocol*. Recuperado de: <https://web.mit.edu/kerberos/>
6. CrowdStrike. (s.f.). *What is a Golden Ticket Attack?*. Recuperado de: <https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/golden-ticket-attack/>
7. FreeRADIUS Project. (s.f.). *The RADIUS Protocol*. Recuperado de: <https://networkradius.com/doc/current/introduction/RADIUS.html>
8. Neuman, C., Yu, T., Hartman, S. y Raeburn, K. (2005). *The Kerberos Network Authentication Service (V5)*. RFC 4120, IETF. Recuperado de: <https://datatracker.ietf.org/doc/html/rfc4120>
9. Rigney, C., Willens, S., Rubens, A. y Simpson, W. (2000). *Remote Authentication Dial In User Service (RADIUS)*. RFC 2865, IETF. Recuperado de: <https://datatracker.ietf.org/doc/html/rfc2865>